SECURITY AND PRIVACY POSTURE

What we built — and what we have not claimed.

Plain language for IT and quality. Pharma QMS is self-hosted pilot software. It is not a validated / Part 11 system.

Controls present in the product

Hosting	You run the stack. Postgres holds plant data. Default desktop bind is loopback only (this machine).
Actors	Demo mode uses a role selector that trusts client identity headers — walkthroughs with synthetic data only. Strict mode (operator-enabled) requires Argon2id password login, optional TOTP, passkeys, OIDC and SAML single sign-on (SAML, passkeys and SCIM are pilot), SCIM provisioning, server-side sessions, hashed API keys and password re-entry for approvals. **The default dev mode trusts identity headers and must never be exposed.**
Audit	Append-only application audit events in a verifiable hash chain with review-by-exception. Tamper-*evident* at application level; **not** WORM storage and not an independent security assessment.
Throttling and outbound	Per-username login throttling (10 failures / 15 minutes, in memory, single node). Connectors, webhooks and SSO metadata fetches go through an address guard against SSRF; connector secrets are encrypted at rest or referenced by restricted names.
Site scoping	**Partial.** Enforced on most record tables, workflow, keys and connectors; documents, supplier master, Schedule M checklist and market authorizations are shared by design; older audit events are filtered best-effort; global connectors and keys are deployment-wide. No independent review.
Transport	Operator-controlled TLS at the edge you choose (compose / k3s ingress). Desktop pilot often uses plain HTTP on localhost.

Explicit non-claims

Validation	Not validated. Not 21 CFR Part 11, EU GMP Annex 11, or WHO computerized-systems certified.
Gateways	No live CDSCO SUGAM, FDA ESG, EMVS, or E2B exchange.
Pen test	No independent penetration test. An AI-assisted security review (Claude) was done and fixed several issues; it is **not an independent audit** and did not cover the frontend source, desktop app, deployment manifests or TLS.
Role checks	Many write endpoints have no per-role check, so a read-only user could call them. Use a read-only front guard for public demos.
Open items	SAML library panic with no patched release (contained); dependency updates needing a newer Go toolchain; unthrottled signature re-entry; TOTP replay within window; single-process design.
Retail	Not Zyvora Pharmacy (retail medical stores).
Data	Built and demonstrated with synthetic / pilot data.

Report a vulnerability

security@zyvor.dev — please do not open public issues with exploit detail.

Intended use

See docs/INTENDED-USE.md on the public site for the full boundary statement.

Read this before a pilot. The public live demo at pharma.zyvor.dev is shared, read-only and synthetic. If your quality unit needs Part 11 evidence packs, those are a customer validation programme — not something this PDF or the software asserts.